מספר התלמיד הנבחן
**רשום את כל תשע הספרות**

**הדבק כאן את מדבקת הנבחן**

**האוניברסיטה הפתוחה**

**ו' באדר תשפ"ג**

27 בפברואר 2023

# מס' שאלון - 538

**סמסטר 2023א**

מס' מועד 91

**4 / 20940**

**שאלון בחינת גמר**

## 20940 - מבוא לאבטחת המרחב המקוון

**משך בחינה: 3 שעות**

בשאלון זה **4** עמודים

**מבנה הבחינה:**

עליכם לענות על ארבע מתוך חמש השאלות.
יש להקפיד על כתב יד קריא.
השתדלו להתחיל כל תשובה בדף חדש.

בהצלחה.

**חומר עזר:**
**מותר לשימוש מחשבון מדעי שלא אוצר מידע.**

**בהצלחה !!!**

**אינכם חייבים**
**להחזיר את השאלון לאוניברסיטה הפתוחה**

**שאלה 1**

נתונה מערכת עם 4 משתמשים: U1, U2, U3, U4 ו4 קבצים F1, F2, F3, F4.

המערכת מממשת את מודל BLP לפי הסווג הבא:

משתמש U1 – סודי , משתמש U2 – סודי ביותר, משתמש U3 – בלמ"ס, משתמש U4 – שמור

קובץ F1 – סודי ביותר, קובץ F2 – סודי, קובץ F3 – שמור, קובץ F4 – בלמ"ס

א. רשמו את מטריצת הגישה המתאימה.
ב. רשמו את המטריצה בצורה של ACL ובצורה של C-List.
ג. האם ניתן לייצג מטריצה זו ב-UNIX (כלומר ב-UNIX קלסי עם 9 ביטים בלבד)? הראו כיצד או הסבירו מדוע לא.
ד. האם ניתן לייצג מטריצה זו ב-WINDOWS? הראו כיצד או הסבירו מדוע לא.
ה. האם יכולה להיות זרימת מידע לא-חוקית במערכת? הראו כיצד או הסבירו מדוע לא.
ו. האם ייתכן ערוץ נסתר במערכת? אם כן, הראו דוגמה לערוץ שכזה. אם לא, הסבירו מדוע.
ז. משתמש U2 מעוניין לכתוב לקובץ F4. באיזה תנאים ניתן לאפשר לו לעשות זאת?

- פרטו כל הנחה שאתם מניחים

**שאלה 2**

כתבו נכון/לא נכון. יש להסביר **בקצרה** את תשובותיכם (2-3 משפטים).

א. פישינג אפשרי רק אם הקורבן לוחץ על קישור זדוני שנשלח לו ע"י התוקף.
ב. Kerberos חסין להתקפת אופליין עבור תוקף פסיבי המאזין להודעות.
ג. חיבור TLS /SSL בינך לבין הבנק יהיה בטוח גם אם הראוטר בביתך נשלט ע"י תוקף.
ד. פונקצית HASH קריפטוגרפית טובה לא מייצרת התנגשויות.
ה. בהצפנת DES במוד CBC הבלוק האחרון יכול לשמש כ-MAC.
ו. ה-CA שהנפיק תעודה עבור אתר site.com יכול לפענח את כל התעבורה של אתר זה.
ז. וירוס מנסה להתפשט לקבצים נוספים במערכת ולהסוות את קיומו.
ח. בתכנון אנטי וירוס או IDS ,יתרון של זיהוי מבוסס אנומליה על פני זיהוי מבוסס חתימות הוא שבדרך זו ניתן לזהות גם התקפות חדשות.
ט. שימוש בקנרית למניעת buffer overflow דורש קימפול (הידור) של הקוד בקומפיילר התומך באופציה זו.
י. בהצפנה ציבורית יש צורך בשליחת המפתח הציבורי בערוץ מאובטח.

**המשך הבחינה בעמוד הבא**

**שאלה 3**

הסבירו חמישה מתוך ששת המושגים הבאים. יש ללוות בדוגמה כשמתאים.

1. SQL Injection
2. ZERO DAY Vulnerability
3. XSS
4. CFB mode
5. חתימה אלקטרונית
6. תולעת

**שאלה 4**

נניח שבמערכת מסוימת החליטו לוותר על שימוש בפונק' hash לחתימה דיגיטלית מבוססת RSA. כלומר, כאשר אליס מעוניינת לשלוח הודעה M חתומה היא שולחת את הזוג (M,S) כאשר

$S=M^d \bmod n$ (d הוא המפתח הפרטי, n הוא מכפלה של 2 ראשוניים מאוד גדולים).

וכמו כן כולם במערכת מכירים את המפתח הציבורי שלה (שהועבר בצורה בטוחה).

בהמשך השאלה נניח שהמפתח הציבורי של אליס הוא 3 (כלומר הזוג (3,n)).

א. בוב מקבל מאליס הודעה חתומה (M,S). הסבירו כיצד מוודא בוב ש-M לא שונתה. (מה הנוסחה המדויקת בה עליו להשתמש?)

ב. מר זדוני מעוניין לשלוח לבוב זוג (M,S) כלשהם כך שבוב יחשוב ש-S היא חתימה תקפה על M (זדוני מכיר רק את המפתח הציבורי של אליס). הראו שהזוג (1,1) יקיים זאת. הראו כיצד זדוני יכול למצוא עוד זוגות (M,S) שיקיימו זאת.

(רמז: M לא חייבת להיות בעלת משמעות, עליה רק לקיים את היחס המתאים עם S כלשהו שאתם יכולים לקבוע את ערכו כרצונכם)

ג. אליס שולחת לבוב הודעה חתומה (M,S) וידוע שההודעה M מכילה מספר בלבד (קטן יחסית ל-n). זדוני חטף את ההודעה ומעוניין להעביר לבוב הודעה חתומה (M',S') כך ש-M'=8M. כיצד הוא יכול לעשות זאת?

ד. הסבירו מדוע ההתקפות של זדוני בסעיפים הקודמים לא יעבדו אם אליס תחתום על hash של ההודעה ולא על ההודעה עצמה.

## המשך הבחינה בעמוד הבא

**שאלה 5**

א. (12 נק') להלן מערכת חוקים לחומת אש מסוג stateless. כתבו את טבלת החוקים המתאימה.

- אפשרו כל תקשורת היוצאת מן הארגון פרט לפורט 15.
- אפשרו כל תעבורת TCP מבחוץ אשר התחילה מתוך הארגון.
- אפשרו תעבורת TCP מבחוץ לשרת האימיילים (SMTP, פורט 25).
- אפשרו תעבורת TCP מבחוץ לשרת ה-WEB (כלומר HTTP ו-HTTPS, פורט 80 ו-443).
- אפשרו תעבורה בפרוטוקול FTP. האם עדיף מוד אקטיבי או פסיבי?

ב. (8 נק') תנו דוגמה לפגיעות Buffer Overflow אשר לא תיעצר ע"י אחת מההגנות הבאות (או שילוב שלהן):

ASLR – רנדומיזציה של פונקציות המערכת

DEP – מניעת הרצת קוד על המחסנית

CANARY – כתיבת ערך ע"י הקומפיילר לפני כתובת החזרה

הסבירו מדוע ההגנות לא יעזרו.

כיצד ניתן למגר פגיעות מסוג זה?

**ב ה צ ל ח ה !**